

✦ Get unlimited access to the best of Medium for less than \$1/week. [Become a member](#)

Zero-click account takeover worth 1500€

☰

Medium

🔍

Search

✍️

Write

🔔

2



-  Home
-  Library
-  Profile
-  Stories
-  Stats

-  Following
-  Abhirup Konwar

•
-  Mr Horbio

•
-  Harshad Shah

•

 Sakshi Rathore

Following

3 min read · 1 hour ago

 53











Hello Everyone, This is the method and steps I followed to uncover a vulnerability that resulted in getting me a bounty of 1500 Euros.

Also, This program doesn't have any Official Bug Bounty Policy but they do reward for critical issues.

Apologies for the bad English.

-  Gökhan Güzelk... •
-  Monika sharma •
-  gayatri r •
-  Aditya Sunny •
-  tinopreter •
-  Mohsin khan •
-  Jerry Shah (Jerry) •
- ▼ More

*I figured out this vulnerability after watching this awesome video from **Magn4** which you can check out too.*

https://youtu.be/_zvFPqYqOhY?si=mGGC_JS3Sz3Lz7o2

So, I was hunting on a website which was related to some medical stuff like something related to things that is required for making medicines and all. I went through the normal registration process, could not find anything there other than some low issues.

Then I analyzed their login flow, but nothing much there. Everything was secure.

In there User profile section, the settings were you cannot change anything there after registration except the email. I tried changing the email and got a link on the new email.

I sent the email change request to repeater and analyzed it. The email was being sent in the Json body with new email, country and some other parameters. I tried playing with it but got nothing.

After it, I analyzed the cookie of the request as there were so many parameters in it so I can just get a bit better understanding of the request.

There I used the Burp extension named request minimizer to remove the unnecessary cookies.



At the end I got this request for a successful execution.

```
1 POST /confirmation-email HTTP/2
2 Host: .com
3 Cookie: events_cid=1294515; events_email=test.vic3456@gmail.com; events_uuid=C20H02A034
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0) Gecko/20100101 Firefox/147.0
5 Accept: application/json, text/plain, */*
6 Accept-Language: en-US,en;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/json
9 X-Amzn-Trace-Id: 1771178058657_422744642
10 Ref_page: https:// /fr/account/personal-data
11 Ts: 1771178058657
12 Ver: v0.0.1121_2026-02-15_10-05
13 Language_id: fr
14 Content-Length: 131
15 Origin: https://
16 Referer: https://
17 Sec-Fetch-Dest: empty
18 Sec-Fetch-Mode: cors
19 Sec-Fetch-Site: same-site
20 Priority: u=0
21 Te: trailers
22
23 {
    "email": "test.vic3456@gmail.com",
    "newEmail": "sakshirathore584@gmail.com",
    "country": "fr".
```

okay so events cid and uuid were changing based on the actions we were performing (as much as I figured) but here the server was actually considering the Email that was in cookies value. As much as it sounds weird to me and others, It was the case.

Now let's take 3 accounts.

Victim@gmail.com

Attacker1@gmail.com

Attacker2@gmail.com

1. I initiated an email change request from Attacker1@gmail.com to Attacker2@gmail.com.
2. I captured the request and changed the email value in the cookie from Attacker1@gmail.com to victim@gmail.com.
3. I got a link on my Attacker2@gmail.com inbox. I approved the email change request and It successfully changed from victim@gmail.com to Attacker2@gmail.com.
4. Now to login into the Victim account I simply have to request a password reset link which will obviously come to Attacker2@gmail.com from where I can just change the password and log into the victim's account.

I reported it to them and they fixed it quickly and also awarded me with a 1500 Euro Bounty.



(I have only the message on my mobile so bear with it but yeah these are the credentials for the Bounty)

So that’s all I hope you like the writeup. Once again apologies for my bad English. See you all later. BBye!!!

- Cybersecurity
- Bug Bounty
- Penetration Testing
- Bug Bounty Tips

 **Written by Sakshi Rathore**
20 followers · 6 following

Following ▾

No responses yet



SANDESH

What are your thoughts?

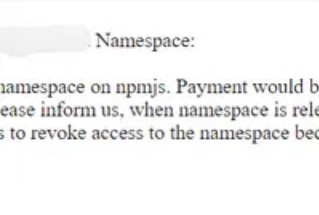
More from Sakshi Rathore



Sakshi Rathore

Dependency Confusion: A Namespace Takeover Story

Hello. I am Sakshi Rathore, a Cyber Security Student and Bug Bounty Hunter.

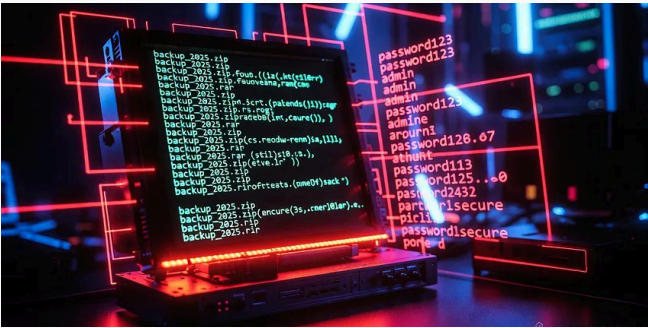


Sep 5, 2024 23



See all from Sakshi Rathore

Recommended from Medium



In LegionHunters by Abhirup Konwar

Fuzzing Wordlists for Backup Files

Custom tiny wordlist to find information disclosure bugs



Ziad (Zierax)

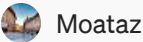
6 Hours, 6 Real-world Critical Bugs: A Case Study in Efficient Bug...

This writeup documents a hunting session where I found 6 critical vulnerabilities in...

Feb 16 33



Feb 15 538 2



Moataz



My First Triaged Report Ever

Introduction

Feb 14 4



Greetings from [REDACTED]

We are reaching out regarding the vulnerabilities you reported to [infosec@\[REDACTED\].com](mailto:infosec@[REDACTED].com):

[REDACTED]

We sincerely appreciate the time and effort you invested in identifying this issue, as well as your expertise in bringing it to our attention. Your findings highlighted something that our development team had overlooked, and we are grateful for your contribution to improving our platform.

After carefully reviewing the severity, business impact, and exploitation context of the reported vulnerability, and following an internal discussion, we have decided to offer you a payment of [REDACTED] in recognition of your efforts in discovering and reporting this bug.

To proceed with the payment, your account details for PayPal, Skrill, Neteller, or your USPIC-FRC20 address. Once



Ahmed Ghadban

\$1000 Bounty for Chaining 2 IDOR's & WAF Bypass to Expose...

Bounty: \$1,000 | Severity: High

Feb 13 80 2



Report Id [REDACTED] Duplicate (Closed)

Severity [REDACTED] High (7 ~ 8.9)



Joe

Account Takeover via OTP bypass

About Me

Feb 3

116

2



ghandarOx

Privilege Escalation Allow Admin to Delete Owner Leading to...

بِسْمِ اللَّهِ الرَّحْمَنِ الرَّحِيمِ

Feb 2

61



See more recommendations